

**CEFET/RJ - CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA**

**PentestAssist — Ferramenta de apoio ao pentest
para iniciantes**

Luis Guilherme Cantanhêde de Paiva

Prof. Orientador:
Ronilson Rodrigues Pinho

**Rio de Janeiro,
Novembro de 2024**

**CEFET/RJ - CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA**

PentestAssist — Ferramenta de apoio ao pentest para iniciantes

Luis Guilherme Cantanhêde de Paiva

Projeto final apresentado em cumprimento às
normas do Departamento de Educação
Superior do Centro Federal de Educação
Tecnológica Celso Suckow da Fonseca,
CEFET/RJ, como parte dos requisitos para
obtenção do título de Bacharel em Sistemas de
Informação.

Prof. Orientador:
Ronilson Rodrigues Pinho

**Rio de Janeiro,
Novembro de 2024**

DEDICATÓRIA

AGRADECIMENTOS

Texto

“Só seria fácil se não fosse difícil”

(Nome do autor)

RESUMO

Texto

Palavras-chaves: Palavra; Palavra; Palavra; Palavra; Palavra

ABSTRACT

Texto

Keywords: Palavra; Palavra; Palavra; Palavra; Palavra

Sumário

1	Introdução	2
1.1	Contextualização	2
1.2	Problema investigado	2
1.3	Motivação	3
1.4	Objetivos	3
1.5	Justificativa	3
1.6	Questões de Pesquisa para o Estudo de Caso	4
1.7	Delimitação do Estudo	4
1.8	Estrutura do Estudo	5
2	Fundamentação Teórica	7
2.1	Segurança da Informação	7
3	Revisão da Literatura / Trabalhos Relacionados	8
4	Proposta	9
5	Conclusão	10
	Referências	11

Lista de Figuras

FIGURA 1:	Exemplo de foto.	6
-----------	--------------------------	---

Lista de Tabelas

TABELA 1:	Exemplo	5
-----------	-------------------	---

Capítulo 1

Introdução

1.1 Contextualização

Com o advento das redes de computadores o mundo passou a ficar cada vez mais conectado, as pessoas passaram a interagir boa parte do tempo através de seus smartphones e computadores, fazendo da internet o principal meio de trégo de informações da idade contemporânea. Prevê-se que mais 125 bilhões de dispositivos IoT(Internet of Thinks - Internet das Coisas)[1] sejam conectados até 2030, o que indica números expressivos de dados trafegando em rede. Logo, as informações que atravessam o cyberspaço tornaram-se ativos de alto valor para as empresas.[2].

Através do vasto volume dados disponiveis em redes houve uma expansão da superfície de ataque sobre a qual cyberataques são elaborados e despendidos diariamente[3]. Em 2021, dados preocupantes mostraram uma alta incidência de ataques, 1 a cada 3 segundos, 1200 por hora. Além disso, as ofensivas têm sido cada vez mais sofisticadas, se utilizando de ataques de dia zero[4].

1.2 Problema investigado

Em 2022, cerca de 3 milhões de vagas para cargos de segurança da informação ficaram em abertas, isso demonstra um inquietante indice de como está sendo o desenvolvimento dos profissionais da área. A área segue com elevados indices de dissonancia entre as qualificações dos candidatos e as habilidade necessárias para cargo, deixando em evidencia a importancia da formação profissional bem estruturada e o mais rápida possível para que a alta demanda seja suprido de forma rápida e com excelência[5].

1.3 Motivação

A presente escassez de profissionais de cybersegurança se motiva, por muitas vezes, da dificuldade do iniciante em conseguir assimilar e empregar os diversos conceitos e práticas que a disciplina exige. Principalmente, quando se trata do uso intensivo da memória a fim de decorar os comandos de CLI necessários para o uso de praticamente todas as ferramentas para execução de testes de vulnerabilidades, enumeração e testes de penetração, o que torna a curva de aprendizagem significativamente íngreme para iniciantes[6].

1.4 Objetivos

Este trabalho tem como objetivo desenvolver e analisar uma ferramenta desktop GUI para apoio a testes de penetração, visando auxiliar o desenvolvimento acadêmico-profissional do estudante da área de TI. A fim de alcançar tal objetivo propõe-se:

- Pesquisar as principais técnicas e metodologias de testes de penetração utilizadas no mercado;
- Analisar as funcionalidades das ferramentas Nmap, Nuclei, Nikto, Caido, Gobuster, Dirsearch, Sqlmap, Commix, Netcat, Metasploit;
- Implementar a virtualização das ferramentas utilizadas através do Docker;
- Projetar e implementar uma interface gráfica;
- Implementar LLM para auxiliar o usuário durante a utilização de ferramentas;
- Avaliar o desempenho da ferramenta desenvolvida em ambiente controlado
- Documentar os resultados obtidos e propor melhorias futuras.

1.5 Justificativa

Apesar da ampla disponibilidade de ferramentas consolidadas para testes de segurança muitos estudantes e profissionais iniciantes encontram dificuldades práticas para usá-las de forma integrada e segura. A curva de aprendizado das interfaces em linha de comando, a diversidade de formatos de saída e a necessidade de montar fluxos reproduzíveis tornam o processo mais

custoso e propenso a erros[6]. Diante disso, este projeto propoe desenvolver o PentestAssist: uma aplicação desktop em Python com interface pyQT6 que orquestre ferramentas, normalize suas saídas em um formato único, gere relatórios técnicos e ofereça fluxos guiados para quem está começando na área.

1.6 Questões de Pesquisa para o Estudo de Caso

A fim de orientar o desenvolvimento da ferramenta as seguintes questões foram levantadas:

1. Como a linguagem de programação escolhida pode ajudar?
2. Qual as dificuldade em executar aplicação em diversos Sistemas Operacionais?
3. De que forma a integração de ferramentas pode aumentar a eficiência da identificação de falhas?
4. Quais dificuldades os profissionais enfrentam ao realizar testes de penetração de forma manual?
5. Qual é o impacto da automatização dos testes de pentest no tempo e na qualidade da análise de vulnerabilidades?
6. Como a integração das ferramentas pode ajudar o profissionais iniciantes?
7. De que forma a LLM vai interagir com o usuário?

1.7 Delimitação do Estudo

O presente estudo se delimita ao desenvolvimento de uma aplicação GUI com o objetivo de integrar as seguintes ferramentas: Nmap, Nuclei, Nikto, Caido, Gobuster, Dirsearch, Sqlmap, Commix, Netcat, Metasploit; de forma virtualizada através de containers Docker. Além disso, conta com a implementação da LLM com o intuito de auxiliar o usuário em seus testes práticos. Não serão abordados desenvolvimento de aplicações web, questões reacionadas a segurança de equipamentos físicos e governança de TI.

1.8 Estrutura do Estudo

Este trabalho está organizado em cinco capítulos, além das referências bibliográficas e dos apêndices.

O Capítulo 1 apresenta a introdução ao tema, abordando a contextualização, o problema investigado, a motivação, os objetivos, a justificativa, as questões de pesquisa e a delimitação do estudo.

O Capítulo 2 reúne a fundamentação teórico, contemplando os principais conceitos relacionados à segurança da informação, testes de penetração, virtualização de ferramentas, integração de ambientes por meio do Docker e desenvolvimento de interfaces gráficas (GUI) em aplicações Python, uso de LLM para auxiliar o usuário, além da análise de trabalhos correlatos.

O Capítulo 3 descreve a metodologia empregada para o desenvolvimento do PentestAssist, detalhando as etapas de pesquisa, as tecnologias utilizadas (Python, PyQt6 e Docker) e o processo de integração das ferramentas de pentest.

O Capítulo 4 apresenta o desenvolvimento da aplicação e os resultados obtidos, destacando a arquitetura do sistema, a interface desenvolvida, os testes realizados e a análise de desempenho em ambiente controlado.

Por fim, o Capítulo 5 traz as conclusões e considerações finais, evidenciando as contribuições do estudo, as limitações observadas e as perspectivas de aprimoramento e continuidade do projeto.

- Primeiro item
- Segundo item
- Terceiro item

Exemplo	Exemplo
Exemplo	Exemplo
Exemplo	Exemplo

Tabela 1: Exemplo

[Nizetic et al., 2020] [Fernandes, 2018] [Ahmad et al., 2023] [Brooks, 2021] [Goupil et al., 2022] [Alaryani et al., 2024] [Cisco, 2020]

?



Figura 1: Exemplo de foto.

Capítulo 2

Fundamentação Teórica

2.1 Segurança da Informação

Inicialmente a Segurança da Informação foi regida por três princípios:

- **Confidencialidade:** este princípio estabelece que uma determinada informação só pode ser acessada por pessoas, sistemas ou entidades devidamente autorizadas, garantindo que seu conteúdo não seja divulgado ou exposto a terceiros sem permissão[Fontes, 2017].
- **Integridade:** assegura que os dados a serem transmitidos não devem, em hipótese alguma, ser alterado, corrompidos ou excluídos por terceiros durante o caminho do remetente até o destino[Fernandes, 2018].
- **Disponibilidade:** determina que os recursos e informações de um sistema devem estar acessíveis aos usuários autorizados sempre que solicitados, minimizando interrupções e garantindo a continuidade das operações[Moreno, 2019].

Com o avanço da tecnologia e a dinamização da internet apenas a tríade - CID - deixou de ser suficiente para garantir a segurança das informações. Portanto houve a necessidade de incluir outros três pilares: autenticidade, responsabilidade e a conformidade legal [ISO/IEC 27001:2013, 2013]

Capítulo 3

Revisão da Literatura / Trabalhos Relacionados

Capítulo 4

Proposta

Capítulo 5

Conclusão

Referências

- Rasheed Ahmad, Izzat Alsmadi, Wasim Alhamdani, and Lo'ai Tawalbeh. Zero-day attack detection: a systematic literature review. *Artificial Intelligence Review*, 56(10):10733–10811, 2023.
- Meera Alaryani, Shamsa Alremeithi, Fatima Al Ali, and Richard Ikuesan. Penthack: Ai-enabled penetration testing platform for knowledge development. In *European Conference on Cyber Warfare and Security*, volume 23, pages 27–36, 2024.
- Chuck Brooks. More alarming cybersecurity stats for 2021! *Forbes*, October, 24, 2021.
- U Cisco. Cisco annual internet report (2018–2023) white paper. *Cisco: San Jose, CA, USA*, 10(1):1–35, 2020.
- Nélia O Campo Fernandes. Segurança da informação. 2018.
- Edison Luiz Gonçalves Fontes. Segurança da informação. *Saraiva Educação SA*, page 2, 2017.
- Francois Goupil, Pavel Laskov, Irdin Pekaric, Michael Felderer, Alexander Dürr, and Frederic Thiesse. Towards understanding the skill gap in cybersecurity. In *Proceedings of the 27th ACM Conference on on Innovation and Technology in Computer Science Education Vol. 1*, pages 477–483, 2022.
- ISO/IEC 27001:2013. ISO/IEC 27001:2013 – Information Technology – Security Techniques – Information Security Management Systems – Requirements. ISO/IEC Standard, 2013. Disponível em: <https://www.iso.org/standard/54534.html>.
- Daniel Moreno. *Introdução ao Pentest*. Novatec Editora, 2019.
- Sandro Nizetic, Petar Soli, Luigi Patrono, et al. Internet of things (iot): Opportunities, issues and challenges towards a smart and sustainable future. *Journal of cleaner production*, 274: 1–32, 2020.